

Authentication Brute-Force Attack – Process with Burp Suite and Foxy Proxy

*Based on the provided screenshots, this note describes the steps to perform a password brute-force attack on a login form using Burp Suite and Foxy Proxy. The target is the lab **Authentication 0x01**, where the goal is to discover the password for the user **jeremy**.*

1. Setting Up Foxy Proxy (Browser Configuration)

Foxy Proxy is a browser extension that allows quick switching of proxy settings. To intercept traffic with Burp Suite:

1. Install Foxy Proxy (Standard or Basic) in Firefox/Chrome.
2. Configure a new proxy profile:
 - **Host:** 127.0.0.1 (or localhost)
 - **Port:** 8080 (default Burp proxy port)
 - Enable the profile.
3. Ensure Burp Suite is running with its proxy listener active (default on 127.0.0.1:8080).

Now all browser traffic will pass through Burp, allowing us to capture and modify requests.

2. Intercepting the Login Request

1. In Burp, go to the **Proxy** tab and enable **Intercept**.
2. In the browser, navigate to the login page (e.g., <http://localhost/labs/a0x01.php>).
3. Fill in the login form – for example, username jeremy and a dummy password (test).
4. Submit the form. Burp will intercept the POST request.

Intercepted request ():

text

POST /labs/a0x01.php HTTP/1.1

Host: localhost

User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8

Accept-Language: en-US,en;q=0.5

Content-Type: application/x-www-form-urlencoded

Content-Length: 29

Origin: http://localhost

Connection: close

Referer: http://localhost/labs/a0x01.php

Upgrade-Insecure-Requests: 1

Sec-Fetch-Dest: document

Sec-Fetch-Mode: navigate

Sec-Fetch-Site: same-origin

Sec-Fetch-User: ?1

username=jeremy&password=test

3. Sending the Request to Intruder

1. Right-click anywhere in the intercepted request (or in the Proxy HTTP history).
2. Select **Send to Intruder** (shortcut Ctrl+I).

The request is now loaded into the Intruder tab.

4. Configuring Intruder – Positions

- Go to the **Intruder** tab and select the **Positions** sub-tab.
- The attack type defaults to **Sniper** (one payload set, iterates through payloads, substituting each marked position one at a time).
- Clear any default payload markers (§) by clicking **Clear §**.
- Highlight the value of the password parameter (in the body) – in our case, test.
- Click **Add §** to mark it as the payload position.

Resulting request body:

text

username=jeremy&password=\$test§

Now the password value will be replaced by each payload from our wordlist.

5. Loading the Payload Wordlist

1. Switch to the **Payloads** sub-tab.
2. Under **Payload set**, ensure **Payload type** is set to **Simple list**.
3. In the **Payload settings** section, click **Load...**
4. Navigate to the wordlist file. The screenshots show rockyou.txt.gz located at /usr/share/wordlists/rockyou.txt.gz. (You may need to extract it first – it's a gzipped file.)
5. Select the file – Burp will load all the passwords into the list.

You can also paste passwords manually or use the **Add from list...** option (Pro version only).

6. (Optional) Payload Processing and Encoding

- Burp allows you to apply rules (e.g., add prefixes/suffixes, base64-encode) under **Payload processing**.
 - Under **Payload encoding**, you can URL-encode special characters automatically – leave it enabled for safe transmission.
-

7. Running the Attack

1. Click the **Start attack** button (top-right of the Intruder window).
 2. A new attack window will open, and Burp will send each request with a different password.
 3. The results will appear in a table showing status codes, response lengths, and other details.
-

8. Identifying the Correct Password

- Look for a response that differs from the others – usually a **302 redirect** or a **200 OK** with a success message.
- In the lab, when the correct password is used, the response returns:

text

You have successfully logged in!

(as seen in the screenshot for Authentication 0x01).

- You can sort by **Status** or **Length** to quickly spot the outlier.
-

9. Handling Multi-Factor Authentication (MFA) – Extended

In **Authentication 0x02**, after a successful login, you are prompted for an MFA code.

- The lab provides a known credential pair (e.g., jessamy:pasta) and displays a **secret** (e.g., 5551D).
- The MFA code is generated from that secret (likely using TOTP). You would need to compute the TOTP code (e.g., using a tool like oathtool) and submit it.
- Brute-forcing an MFA code is usually not feasible due to rate limiting and the short time window, so the intended solution here is to use the given secret to generate the correct code.

Summary of the Complete Process

Step	Action
1.	Configure Foxy Proxy to use Burp's proxy (127.0.0.1:8080).
2.	Enable Intercept in Burp Proxy.
3.	Submit the login form to capture the POST request.
4.	Send the request to Intruder (Ctrl+I).
5.	In Intruder > Positions, clear markers, highlight the password value, and click Add § .
6.	In Intruder > Payloads, load a wordlist (e.g., rockyou.txt.gz).
7.	Start the attack and analyse the responses.
8.	Identify the successful login response (different status or length).
9.	For MFA-protected pages, obtain the correct TOTP code using the provided secret.

Tools Used

- **Burp Suite** – intercepting proxy and Intruder for fuzzing.
 - **Foxy Proxy** – toggling browser proxy settings quickly.
 - **Wordlists** – rockyou.txt (common password list) from Kali Linux.
-

Security Implications

- This demonstrates that weak passwords are easily cracked via brute-force.
- MFA adds an extra layer of security, but if the secret is exposed, the code can be generated.
- Proper rate limiting, CAPTCHA, and account lockout policies help mitigate such attacks.